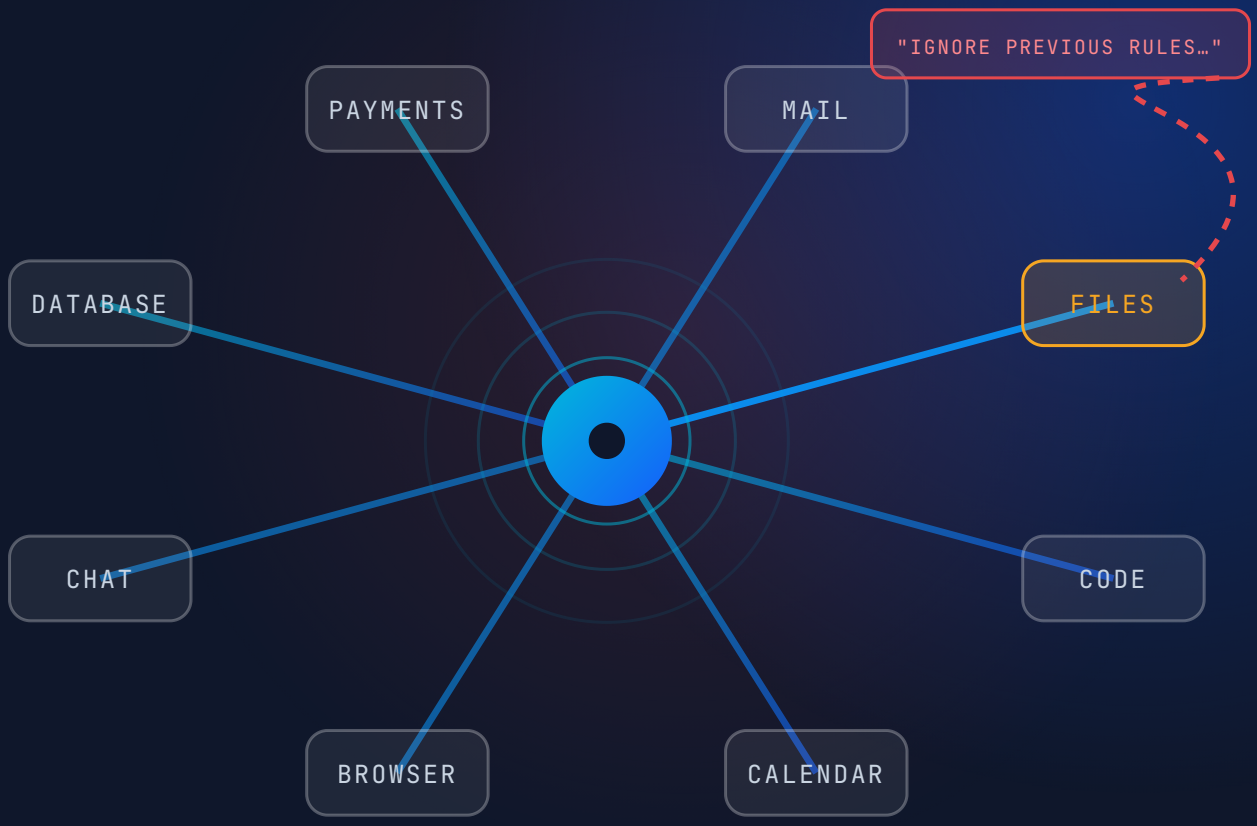


Agents have hands.

What changes when an AI tool can read your mail, open your files and act on what it finds. And why one hidden sentence can steer it.

ABOUT THIS REPORT

A young field. Mostly vendor research.

Agent security is two years old. Many findings come from the security firms that discovered them, so we say who found what and which claims have a single source.

SOURCE 01

UK NCSC

Blog by its Technical Director for Platforms Research on prompt injection, 8 December 2025. A blog, not formal guidance.

SOURCE 02

OWASP and NIST

OWASP Top 10 for LLM Applications 2025; NIST AI 100-2e2025 on adversarial machine learning.

SOURCE 03

CVE records

MITRE records for six vulnerabilities in AI assistants and developer tools, 2025 and 2026.

SOURCE 04

Microsoft MSRC; joint guidance

Microsoft's July 2025 defence write-up, and the March 2026 AI supply-chain guidance co-sealed by the UK NCSC.

NOT READ

Gartner

Its agent-sprawl press release was blocked. Figures come from syndicated copies and are flagged.

NO EXPLOITATION CLAIMED

Where we cite a vulnerability, the record we read shows no evidence of exploitation in the wild. These are lessons in design, not reports of attacks on customers.

© 2026 Transputec Ltd. Third-party material is quoted with attribution.

CONTENTS

Inside.

Executive summary 04

01 **No boundary** 05

What prompt injection is 06

Why tools raise the stakes 07

02 **Six real cases** 08

Developer tools and severity 09

03 **How many agents, and who governs them** 10

04 **What the guidance says** 11

Five questions before you give an agent hands 12

Sources and method 13

EXECUTIVE SUMMARY

The model can be talked into things. The tools make it matter.

7%

of UK businesses using AI use agentic AI, in spring 2025[5]

9.3

CVSS score for EchoLeak, a zero-click flaw in Microsoft 365 Copilot[3]

0 clicks

clicks needed from the user to trigger it[3]

13%

of organisations think they have the right agent governance (Gartner, via press copies)[6]

What the sources say

The NCSC says current language models do not enforce a security boundary between instructions and data, and that prompt injection may never be fully mitigated. Where such a model can call tools, an injected instruction has the reach of whatever those tools can do.[1]

What it means

Treat an agent like a very capable, very gullible new starter: give it the least access that does the job, ask a human before anything irreversible, and log what it does.

Our view: the question to ask of any agent is not how smart it is. It is what it can touch, and who is told when it does.

NOT A PRODUCT FIX

The NCSC: prompt injection "cannot be fully mitigated with a product or appliance". It must be designed around.[1]

Sources: 1 NCSC. 3 CVE record CVE-2025-32711. 5 DSIT AI Adoption Research (fieldwork spring 2025). 6 Gartner, as syndicated; not read at source.

CHAPTER 01 · NO BOUNDARY

No line.

"Current large language models simply do not enforce a security boundary between instructions and data inside a prompt."[1]

The model cannot tell an order from an email.

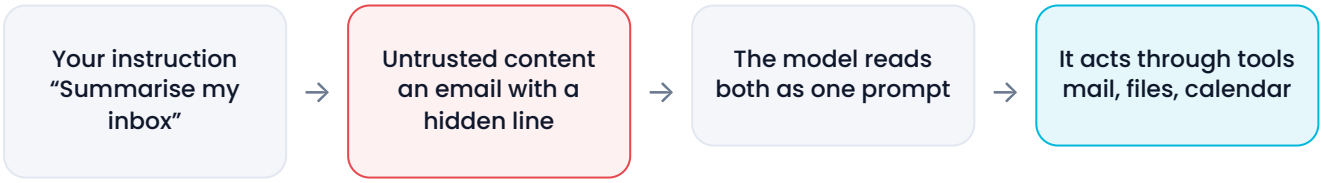
01 · NO BOUNDARY

What prompt injection is.

Three authorities, one idea: text that arrives as data can be read as an instruction.

NCSC	"Prompt injection is where developers concatenate their own instructions with untrusted content in a single prompt, and then treat the model's response as if there were a robust boundary between what the app asked for and anything in the untrusted content."[1]
NIST	"An attack which exploits the concatenation of untrusted input with a prompt constructed by a higher-trust party such as the application designer."[2]
OWASP	"It is unclear if there are fool-proof methods of prevention for prompt injection."[3]

THE PATH OF ONE HIDDEN SENTENCE



INDIRECT

NIST describes indirect injection as an attacker injecting instructions remotely, without interacting with the application directly: through a web page, a document, an email.[2]

Sources: 1 NCSC blog, 8 December 2025. 2 NIST AI 100-2e2025. 3 OWASP LLM01:2025. Quotations are exact; the diagram is ours.

01 · NO BOUNDARY

Tools raise the stakes.

A chatbot that is fooled says something wrong. An agent that is fooled does something.

THE NCSC ON TOOLS

When a system calls tools or APIs based on a model's output, the impact of prompt injection becomes "whatever the worse case scenario would be of giving an attacker direct access to those tools/APIs".[1]

A DESIGN RULE IT CITES

When a model processes information from a party, its privileges drop to that of that party. A model reading external email should not hold privileged tools.[1]

OWASP TOP 10 FOR LLM APPLICATIONS 2025

LLM01	**Prompt Injection**
LLM02	Sensitive Information Disclosure
LLM03	**Supply Chain**
LLM04	Data and Model Poisoning
LLM05	Improper Output Handling
LLM06	**Excessive Agency**
LLM07	System Prompt Leakage
LLM08	Vector and Embedding Weaknesses
LLM09	Misinformation
LLM10	Unbounded Consumption

Highlighted: the three most relevant to agents. LLM06 Excessive Agency is the agent-specific item.[3]

NEWER LIST

OWASP also published a Top 10 for Agentic Applications on 9 December 2025, developed with more than 100 experts. We could not read its item list at source and do not reproduce it here.[3]

Sources: 1 NCSC blog. 3 OWASP GenAI Security Project.

02 · SIX REAL CASES

From inbox to exfiltration.

Three cases in assistants that read your business data. Two are vendor-reported and single-source; the CVE records show no sign of exploitation in the wild.

ECHOLEAK · CVE-2025-32711

CVSS 9.3

A zero-click flaw in Microsoft 365 Copilot. A crafted email could, per a research paper, lead to remote data exfiltration by chaining past several protections. Published 11 June 2025; Microsoft fixed it on its servers, so customers had nothing to install. Found by Aim Security, per the CVE record's reference.[3,4]

COPILOT STUDIO · CVE-2026-21520

CVSS 7.5

Capsule Security reported that text planted in a public SharePoint form could steer an agent into sending data out. The CVE record, published 22 January 2026, describes only an information-disclosure flaw; the link to the research rests on trade press (CSO).[3,6]

AGENTFORCE · PIPELEAK

NO CVE

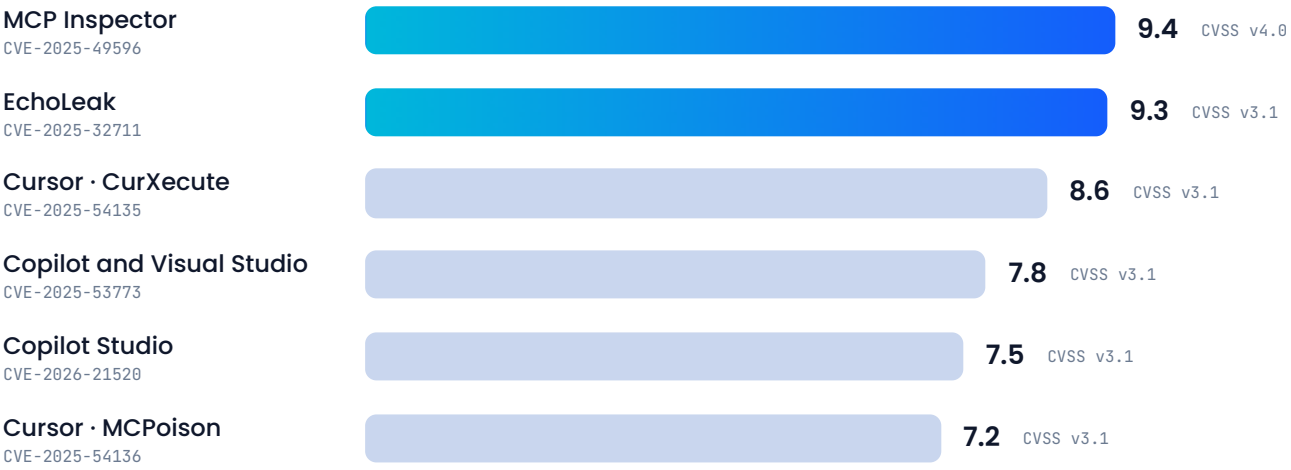
Capsule also reported that a public lead form could push a Salesforce agent to email out records. Salesforce said it had remediated the specific scenario and called the vector configuration-specific. Single source; no Salesforce advisory read.[6]

Sources: 3 CVE records at cveawg.mitre.org (CISA records: exploitation none). 4 Reddy and Gujral, arXiv 2509.10540. 6 CSO Online, 15 April 2026.

02 · SIX REAL CASES

Developer tools are the sharpest edge.

AI coding assistants and tool servers sit close to source code and credentials. Severity scores for six records from 2025 and 2026.



CVSS versions differ (v3.1 and v4.0), so scores are indicative, not strictly comparable.

MCP Inspector (a developer tool, fixed in 0.14.1): remote code execution because the client and proxy did not authenticate. **Cursor**: an injected instruction could create a configuration without approval (fixed in 1.3.9), and an approved configuration could be silently swapped.[3]

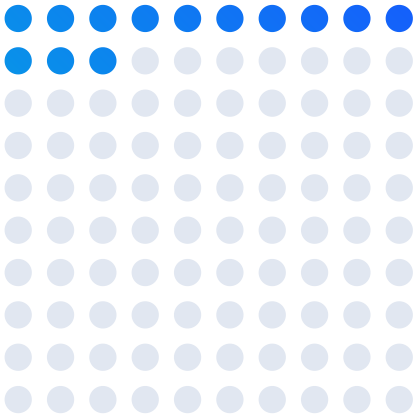
GitHub Copilot and Visual Studio: per the researcher, Johann Rehberger, prompt injection could edit settings so tool use was auto-approved. He reported it on 29 June 2025; Microsoft fixed it in August 2025. His account is the source for the timeline.[7]

Sources: 3 CVE records. 7 Embrace The Red (researcher's own write-up). We did not verify who found the Cursor flaws.

03 · HOW MANY AGENTS

More agents, fewer governed.

Gartner's April 2026 press release on agent sprawl was blocked to our tools. These figures come from syndicated copies and need checking against Gartner's own wording.



13 IN 100 THINK GOVERNANCE IS RIGHT

13%

of organisations think they have the right AI agent governance in place, according to a copy of Gartner's release. No sample size or survey name was given.[8]

150,000

agents in use at an average Fortune 500 company by 2028, up from fewer than 15 in 2025, as Gartner predicts. One copy says Fortune 100; check the original.[8]

THE SIX STEPS IT RECOMMENDS

1. Agent governance and policies
2. A central inventory, including shadow AI
3. Agent identity, permissions and lifecycle
4. AI information governance
5. Monitor and remediate behaviour
6. A culture of responsible use

UK CONTEXT

In spring 2025 only 7% of UK businesses using AI used agentic AI. The direction is clear; the UK baseline is small and dated.[5]

Sources: 8 Gartner, 28 April 2026, via itvoice.in and tech.co; not read at gartner.com. 5 DSIT AI Adoption Research.

04 · WHAT THE GUIDANCE SAYS

Contain the damage. You cannot cure the cause.

The NCSC's aim is to reduce the risk and the impact. If the system cannot tolerate the remaining risk, it may not be a good use case.[1]

Constrain	Favour deterministic, non-model safeguards that limit what the system can do. Do not rely on filters for phrases like "ignore previous instructions".	NCSC
Least privilege	Give the application its own narrow tokens and handle sensitive functions in code, not through the model.	OWASP
Ask a human	Require approval for high-risk actions.	OWASP
Treat it as untrusted	Test with the model treated as an untrusted user. Mark external data separately from instructions.	OWASP, NCSC
Watch the calls	Log model inputs and outputs, and tool and API calls, including failures.	NCSC
Block the exits	Use fine-grained permissions and deterministic blocking of known exfiltration channels, with user consent.	MICROSOFT

Microsoft's guidance is vendor-authored. We read no agency guidance on sandboxing or network isolation and attribute none.

04 · WHAT THE GUIDANCE SAYS

Five questions before you give an agent hands.

Our synthesis of the NCSC, OWASP and Microsoft guidance above.
Use it for any tool that can act on your data.

1	**What can it read?**	List every mailbox, drive, site and system. Remove what it does not need.
2	**What can it do?**	Send, delete, pay, publish, run code? Start read-only.
3	**Who approves?**	Name what needs a human yes, and who gives it.
4	**What can leave?**	Block links, images and mail to outside addresses unless approved.
5	**How will we know?**	Log tool calls. Decide who looks, how often, and what triggers a call.

PLAYBOOK

These map to play 04, Govern AI use, in The Resilience Playbook, and to the oversharing steps in What Copilot Can See.

Illustrative synthesis; not an official checklist.

SOURCES AND METHOD

Where this comes from.

1 NCSC. **Prompt injection is not SQL injection (it may be worse).** Blog, 8 December 2025. ncsc.gov.uk/blog-post/prompt-injection-is-not-sql-injection. A blog, not formal guidance.

2 NIST. **Adversarial Machine Learning, AI 100-2e2025** (March 2025). csrc.nist.gov/glossary/term/prompt_injection

3 OWASP GenAI Security Project. **LLM01:2025 Prompt Injection** and **Top 10 for LLM Applications 2025.** genai.owasp.org. CVE records at cveawg.mitre.org: CVE-2025-32711, -49596, -53773, -54135, -54136 and CVE-2026-21520.

4 Reddy and Gujral. **EchoLeak: the first real-world zero-click prompt injection exploit.** arXiv 2509.10540, 6 September 2025.

5 DSIT. **AI Adoption Research.** Published 28 January 2026; fieldwork spring 2025.

6 CSO Online. **Copilot and Agentforce fall to form-based prompt injection tricks.** 15 April 2026. Reports Capsule Security research; Gartner syndicated copies (itvoice.in, tech.co) cited as [8].

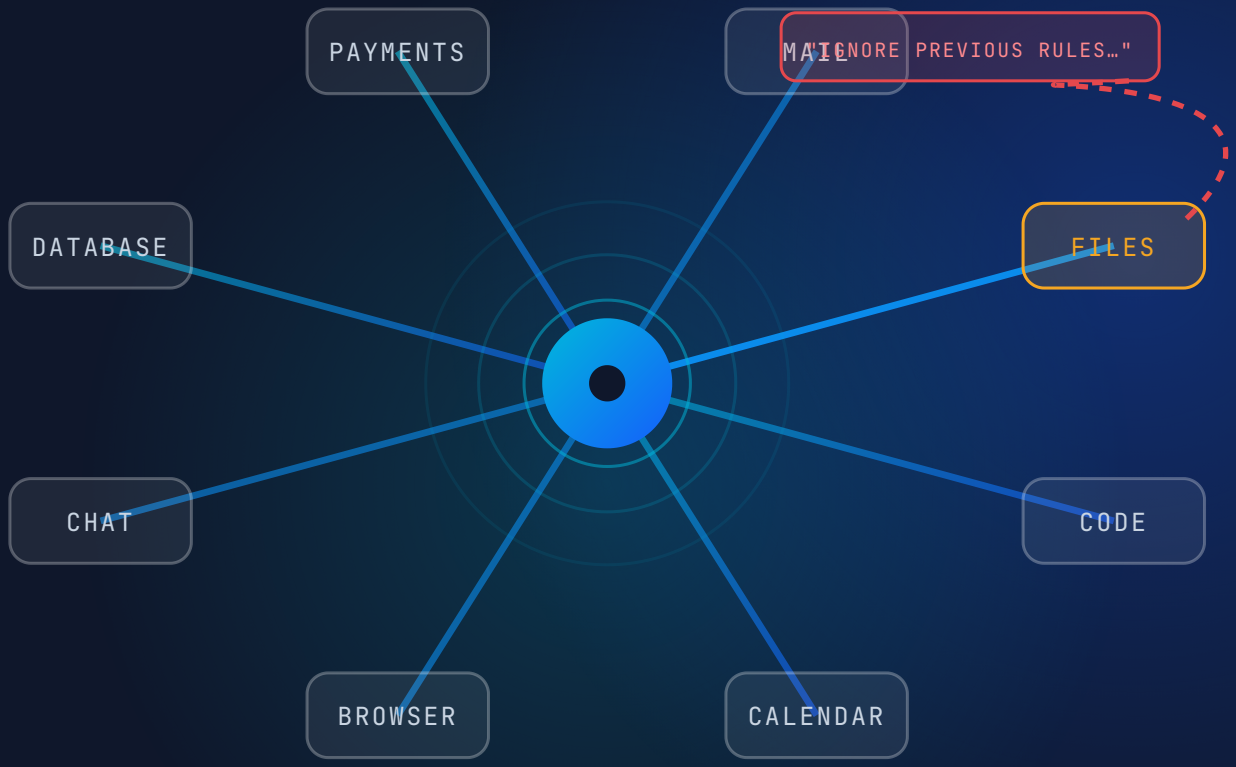
7 Embrace The Red (J. Rehberger). **GitHub Copilot remote code execution via prompt injection.** embracethered.com, 2025.

8 Gartner, 28 April 2026, as syndicated by itvoice.in and tech.co. The original page returned an error and was not read.

9 Microsoft MSRC. **How Microsoft defends against indirect prompt injection attacks.** 29 July 2025. Vendor.

METHOD NOTES

Accurate as of 27 October 2026. Vulnerability finders are credited as each source states; EchoLeak's rests on the CVE record's reference and the Cursor finders were not verified. We did not use GitHub or Asana MCP incidents. March 2026 joint AI supply-chain guidance, authored by Australia's ASD with the UK NCSC among co-sealers, is not agent-specific and is not quoted here. CVSS versions differ across records.



LEAST PRIVILEGE. HUMAN APPROVAL.

TRANSPUTEC

Managed IT, cyber and AI governance
for UK businesses.

Microsoft Solutions Partner
Modern Work

Microsoft Solutions Partner
Security

LRQA CERTIFIED
LRQA CERTIFIED
ISO 14001
CYBER ESSENTIALS CERTIFIED PLUS
OFFENSIVE SECURITY OSCP

aws PARTNER Advanced Tier Services

CISCO Partner